

EXECUTIVE DESIGN BRIEF

Northstar Target-State Security Architecture

Secure access. Limited blast radius. Resilient recovery.

DECISION

Approve the proposed target-state architecture as the security design baseline for phased implementation. The design replaces broad internal trust with explicit, identity-aware, resource-specific access and isolates privileged, security, vendor, and recovery functions from ordinary user activity.

Decision Snapshot

Area	Target State
Security stance	Deny unless explicitly allowed
Primary objective	Prevent one compromised user/device/vendor path from becoming enterprise-wide compromise
Architecture pattern	Segmented zones + identity-aware access + protected admin/vendor paths
Recovery posture	Separate Backup/Recovery Zone + off-site immutable/isolated copy
Validation result	Finance endpoint compromise contained to authorized user-level exposure

1. Architecture at a Glance

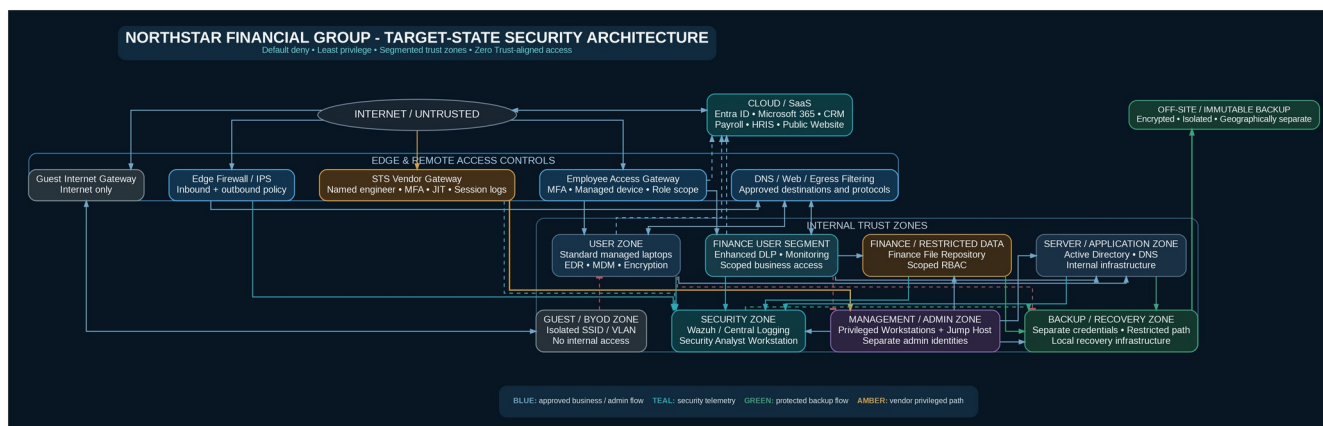


Figure 1. Product-neutral target-state architecture illustrating trust zones, controlled remote/vendor paths, centralized security telemetry, and isolated recovery.

2. Key Executive Decisions

- Keep public website and SaaS services outside the internal trust boundary; allow only explicitly required integrations.
- Separate employee remote access from STS vendor privileged access so one can be disabled without disrupting the other.
- Require privileged administration through dedicated identities, privileged workstations, and jump hosts - not ordinary email/browser endpoints.
- Segment Finance data, Security tooling, and Backup/Recovery infrastructure from ordinary user networks.
- Restrict outbound traffic as well as inbound traffic, including DNS/web/egress policy and tighter server internet access.
- Permit machine-to-machine flows only for specific functions such as telemetry and backup; communication requirement does not equal broad trust.

3. Risk Reduction and Implementation Priorities

Risk Scenario	Architecture Response
Compromised employee endpoint	RBAC + segmentation + peer-to-peer restrictions limit access to authorized resources.
Compromised administrator	Separate identity/workstation and protected admin path reduce exposure of standing privilege.
Compromised vendor	Dedicated STS gateway, MFA, JIT, session logging, and scoped destinations reduce third-party blast radius.
Ransomware / destructive event	Backup Zone isolation plus off-site immutable/isolated copy prevents one credential/location from eliminating recovery.
Security blind spot	Centralized Wazuh telemetry across critical zones supports investigation and recovery monitoring.
Sensitive data leakage	DLP, approved channels, encryption, controlled exports, and TTL/deletion requirements reduce data movement risk.

Implementation Priority

- 0-30 days: approve zone/flow policy, isolate guest access, formalize privileged/vendor identity ownership, and document required cross-zone flows.
- 31-60 days: implement segmentation, employee/vendor access gateways, MFA/device compliance, privileged jump host, and outbound filtering.
- 61-90 days: complete Backup Zone isolation/off-site recovery, Finance DLP, endpoint baselines, and controlled SaaS integrations.
- 90-180 days: expand JIT/PAM automation, validate microsegmentation, exercise architecture failure scenarios, and remove unnecessary exceptions.

Executive Approval Conditions

Production implementation should proceed only after IT/Security validate product-specific firewall rules, high availability, performance, licensing, cost, integration behavior, backup restoration, and rollback procedures. The document is a target-state security design, not a finalized procurement or deployment blueprint.

Recommendation: APPROVE TARGET STATE FOR PHASED IMPLEMENTATION